

WHEN AI ATTACKS

AI THREAT ASSESSMENT WORKBOOK

Digital Content #4 — Model Farming: The Infrastructure Behind AI Model Theft at Scale

Purpose: Assess your organization's exposure to model farming — automated, multi-target AI extraction infrastructure operating against your model APIs. Map the governance gap, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do you have a current inventory of all externally accessible model API endpoints?	☐	☐	☐	
Do shadow deployments and partner integrations appear in that inventory?	☐	☐	☐	
Do all APIs require authentication before serving model responses?	☐	☐	☐	
Do you know which of your model APIs return logit-level outputs (confidence scores / probability distributions)?	☐	☐	☐	
Have APIs returning probabilistic outputs had a query-efficiency risk assessment? (Logit outputs are 10–30× more extraction-efficient.)	☐	☐	☐	
Are rate limits configured per authenticated client on all model APIs?	☐	☐	☐	
Can you detect when a single operator queries through multiple separately provisioned accounts?	☐	☐	☐	
Do you have a process for offboarding API credentials when a partner relationship ends?	☐	☐	☐	

API INVENTORY (list externally accessible model endpoints)

API / Endpoint	Auth Required?	Response Type	Rate Limited?	Owner

02 Output Payload Audit

Logit-level outputs accelerate extraction attacks by 10–30× versus hard-label-only APIs. Audit each API's response payload against client requirements.

Question	Yes	No	Unknown / Gap	Notes
For each API, have you documented what response types are required for client use cases?	☐	☐	☐	
Have you assessed whether confidence scores / logits are functionally necessary for each client?	☐	☐	☐	
Do APIs returning logit-level outputs have a documented business justification?	☐	☐	☐	
Have you evaluated whether hard-label-only responses would satisfy client requirements?	☐	☐	☐	
Have response payloads been reviewed by security for unintended information disclosure?	☐	☐	☐	

PAYLOAD REVIEW: For each API, document the response type and justify it

API / Endpoint	Response Type	Business Justification	Recommended Change

03 Detection Baseline

Volume-based rate limiting is insufficient. Farming operations distribute queries across accounts and slow extraction timelines to stay below thresholds.

Question	Yes	No	Unknown / Gap	Notes
Do you log all API queries at the gateway layer with per-account attribution and timestamps?	☐	☐	☐	
Are per-account query volume baselines established and monitored?	☐	☐	☐	
Do you have alerting on anomalous query volume relative to per-account baselines — not just global thresholds?	☐	☐	☐	
Do you have semantic analysis on query content — input diversity, distributional patterns, edge case density?	☐	☐	☐	
Can you detect boundary-probing patterns (progressive variable manipulation, systematic edge case clustering)?	☐	☐	☐	
Can you identify query formatting uniformity inconsistent with organic application usage?	☐	☐	☐	
Does your SIEM have defined signatures or ML models for adversarial query behavior?	☐	☐	☐	

Have you tested detection capability with simulated farming queries distributed across multiple accounts?	☐	☐	☐	
Do you have canary queries or watermarked output patterns that would surface if a surrogate were deployed?	☐	☐	☐	

04 Governance Gap — Who Owns What

A farming operation may be running right now. Map ownership before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
Model API security monitoring and per-account behavioral analysis			
Query anomaly detection and semantic monitoring alerting			
Incident response — model extraction and surrogate deployment events			
Legal response — IP theft, attribution evidence, and surrogate litigation			
Data governance — obligations on extracted surrogates and model IP classification			
Intelligence sharing — ISAC participation and sector AI security working groups			
API credential lifecycle — provisioning, rotation, and offboarding			

05 Five Questions for Your Next Executive Meeting

Question	Your Answer / Status
01 How would we know if our proprietary model were being systematically extracted right now — across multiple authenticated accounts operating simultaneously?	
02 Do we have semantic monitoring on our API outputs, or only volumetric monitoring? Who owns closing that gap, and by when?	
03 Are our model APIs returning logit-level outputs where hard-label responses would satisfy client requirements — and have we assessed the extraction efficiency difference?	
04 If a competitor deployed a surrogate of our model tomorrow, are our outputs marked in a way that would allow us to confirm the source? What is our legal standing?	
05 Are we participating in any intelligence sharing arrangement that would surface a cross-sector farming operation targeting our industry vertical before surrogates are deployed?	

06 Directives — Assign an Owner and a Date

#	Audience	Directive	Owner	Done By
01	CISO	Inventory every externally accessible model API endpoint. Include shadow deployments and partner integrations. Assume your list is incomplete.		
02	CISO	Audit API response payloads. If you return logit-level outputs, assess whether hard-label responses would satisfy client requirements.		
03	CISO	Classify deployed model behavior as a protectable asset. Define what constitutes a breach of that asset class.		
04	CISO	Assign a named owner for model security posture post-deployment. If no role exists, that is your highest-priority governance finding.		
05	CISO	Update your breach definition to explicitly cover model knowledge extraction — not just data records accessed or exfiltrated.		
06	CISO	Engage legal on IP documentation, output watermarking capability, and attribution evidence requirements.		
07	CISO	Engage your sector ISAC and relevant AI security working groups. Farming operations target industry verticals. Intelligence sharing is a detection control.		
08	IR	Implement semantic query monitoring. Define baseline query distributions for each model API. Build distributional anomaly alerts — this is your primary detection layer.		
09	IR	Establish per-account query volume baselines for all model APIs. Anomaly detection against per-account baselines is your earliest detection signal.		
10	IR	Deploy output watermarking or canary response mechanisms. These enable post-hoc confirmation of extraction events and provide legal standing.		
11	IR	Define model farming in your IR playbook: detection trigger, account isolation steps, legal notification threshold, and evidence set.		
12	IR	Run a cross-functional accountability tabletop: if our model were being farmed across twelve accounts today, who detects it, who owns the response, and what do we tell the board?		

Assessment prepared by Matsui LLC · matsuihq.ai